

QuoteCraft Architecture Review

Executive Summary

- Critical security and availability gaps exist in the Azure PostgreSQL configuration, including public network access and permissive firewall rules.
- Redis (ElastiCache) is deployed single-AZ without encryption in transit, creating both availability and security risks.
- Over-provisioned AWS EFS throughput is causing unnecessary cost.
- RBAC permissions for the QuoteCraft operator are overly broad, violating least-privilege policy.
- There are inconsistencies and gaps in secrets management documentation and implementation.

Findings

F-01: Azure PostgreSQL Public Access and Open Firewall

- Severity: Critical
- Dimension: Security, Availability
- Evidence:
- Source: infra/azure/postgres.tf
- Quote: "public_network_access_enabled = true" and "azurerm_postgresql_flexible_server_firewall_rule" with "start_ip_address = '0.0.0.0'" and "end_ip_address = '255.255.255.255'"
- Policy reference: ARS-15 (Database network exposure), CKS-06 (Cloud service hardening)
- Why it matters: The database is accessible from any IP on the public internet, exposing sensitive customer and quote data to potential attack and increasing the risk of data breach or denial-of-service.
- Remediation: Immediately restrict firewall rules to only required subnets and disable public network access; ensure only private endpoints are used.
- Confidence: High

F-02: Redis (ElastiCache) Single-AZ and No Encryption in Transit

- Severity: High
- Dimension: Availability, Security
- Evidence:
- Source: infra/aws/elasticache.tf
- Quote: "num_cache_nodes = 1", "availability_zone = '\${var.aws_region}a'", "transit_encryption_enabled = false"
- Source: docs/capacity-plan.md
- Quote: "Multi-AZ ElastiCache replication (QC-177)" and "TLS in transit is not enabled. Enabling it would require an application change (rediss:// URL and CA bundle). Tracked in QC-176."
- Policy reference: ARS-21 (Multi-AZ for stateful services), CKS-09 (Encryption in transit)
- Why it matters: Single-AZ Redis is a single point of failure; lack of encryption in transit exposes session and rate-limiter data to interception within the VPC.
- Remediation: Enable Multi-AZ Redis replication and enforce TLS in transit; update application to support rediss://.

- Confidence: High

F-03: Over-Provisioned AWS EFS Throughput

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: infra/aws/efs.tf
- Quote: "provisioned_throughput_in_mibps = 200" and comment: "PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-07 (Cost optimization for managed storage)
- Why it matters: EFS is provisioned for 200 MiB/s throughput, which is not required, resulting in unnecessary monthly spend.
- Remediation: Reduce EFS provisioned throughput to match actual usage.
- Confidence: High

F-04: Overly Broad RBAC Permissions for Operator ServiceAccount

- Severity: High
- Dimension: Security
- Evidence:
- Source: deploy/openshift/rbac.yaml
- Quote: "apiGroups: ['*'] resources: ['*'] verbs: ['*']" and comment: "Role was copied from an earlier internal tool and never tightened."
- Policy reference: CKS-04 (Principle of least privilege)
- Why it matters: The operator ServiceAccount can perform any action on any resource in the namespace, increasing risk of accidental or malicious changes.
- Remediation: Restrict Role to only required resources and verbs for operator functionality.
- Confidence: High

F-05: Inconsistent and Unclear Secrets Management Documentation

- Severity: Medium
- Dimension: Evidence Quality, Security

- Evidence:
- Source: docs/architecture.md
- Quote: "Secrets are sourced from Azure Key Vault via the External Secrets Operator"
- Source: docs/runbook.md
- Quote: "Secrets are managed in HashiCorp Vault. The External Secrets Operator... materialises them as Kubernetes Secrets"
- Policy reference: ARS-12 (Secrets management consistency)
- Why it matters: Conflicting documentation on whether Azure Key Vault or HashiCorp Vault is the source of truth for secrets increases risk of operational error and audit failure.
- Remediation: Clarify and update documentation and implementation to ensure a single, authoritative secrets source.
- Confidence: High

F-06: Redis Rate Limiter Not Cluster-Aware

- Severity: High
- Dimension: Availability, Scalability
- Evidence:
- Source: docs/runbook.md
- Quote: "current in-memory rate limiter when the service is scaled to multiple pods — each pod enforces the limit independently. Until QC-201 is delivered, reducing replica count to 1 during partner-test windows is the workaround."
- Policy reference: ARS-23 (Distributed state consistency)
- Why it matters: Rate limiting is not enforced globally, leading to inconsistent enforcement and potential partner dissatisfaction or abuse.
- Remediation: Implement a distributed rate limiter using Redis or another shared backend.
- Confidence: High

F-07: EFS File System Policy Allows All Principals

- Severity: High
- Dimension: Security
- Evidence:
- Source: infra/aws/efs.tf

- Quote: "Principal = { AWS = '*' }" in file system policy
- Policy reference: CKS-06 (Cloud service hardening)
- Why it matters: Any AWS principal can mount and access the EFS file system, risking data exfiltration or tampering.
- Remediation: Restrict EFS file system policy to only required principals (e.g., specific roles or accounts).
- Confidence: High

F-08: S3 Quote Archive Lacks Lifecycle Policy for Cost Optimization

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: infra/aws/s3.tf
- Quote: "No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-07 (Cost optimization for managed storage)
- Why it matters: Long-term storage of quote PDFs in STANDARD class is unnecessarily expensive given 7-year retention.
- Remediation: Implement S3 lifecycle policy to transition older objects to Glacier or Deep Archive.
- Confidence: High

F-09: PostgreSQL Not Configured for Zone-Redundant High Availability

- Severity: High
- Dimension: Availability
- Evidence:
- Source: docs/capacity-plan.md
- Quote: "High availability: single-zone (see 'Open items' below)" and "Zone-redundant HA for Postgres (QC-193)"
- Policy reference: ARS-21 (Multi-AZ for stateful services)
- Why it matters: Single-zone Postgres is a single point of failure; AZ outage would cause extended downtime.
- Remediation: Enable zone-redundant high availability for Azure PostgreSQL Flexible Server.

- Confidence: High

F-10: Disaster Recovery Not Yet Exercised

- Severity: Medium
- Dimension: Availability
- Evidence:
 - Source: docs/capacity-plan.md
 - Quote: "DR exercise: not yet performed. Scheduled for Q3 2026."
 - Source: docs/runbook.md
 - Quote: "TODO" under both "Single-AZ loss" and "Full region loss"
- Policy reference: ARS-30 (Disaster recovery testing)
- Why it matters: Without DR testing, recovery time and data loss objectives are unproven, risking regulatory and business impact in a real incident.
- Remediation: Complete and document a DR exercise as scheduled.
- Confidence: High

F-11: Deployment Replica Count and HPA Configuration Inconsistency

- Severity: Medium
- Dimension: Evidence Quality, Availability
- Evidence:
 - Source: deploy/openshift/deployment.yaml
 - Quote: "replicas: 1" and "nodeSelector: failure-domain.alpha-paas.com/zone: '1'"
 - Source: docs/architecture.md
 - Quote: "QuoteCraft runs as three pairs of pods distributed across the three availability zones... HPA adjusts replica count between 6 and 30"
- Policy reference: ARS-11 (Deployment configuration consistency)
- Why it matters: The deployment manifest specifies a single replica in a single zone, contradicting the architecture and capacity plan, risking reduced availability and scalability.
- Remediation: Align deployment manifest with intended multi-AZ, multi-replica configuration and ensure HPA is enabled.
- Confidence: High

F-12: AWS IAM User Access Keys Used Instead of IRSA

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: deploy/openshift/secret-aws-keys.yaml
- Quote: "Long-lived IAM user access keys... There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Policy reference: CKS-07 (Ephemeral credentials for cloud access)
- Why it matters: Long-lived access keys are more susceptible to compromise and do not support fine-grained, auditable access control.
- Remediation: Prioritize migration to IRSA for AWS access from pods.
- Confidence: High

Highest Priority Next Actions

1. ****Restrict Azure PostgreSQL public access and firewall rules immediately; ensure only private endpoints are used.****
2. ****Enable Multi-AZ and encryption in transit for Redis (ElastiCache); update application to support rediss://.****
3. ****Tighten RBAC permissions for the operator ServiceAccount to least privilege.****
4. ****Restrict EFS file system policy to only required AWS principals.****
5. ****Align deployment configuration to ensure multi-AZ, multi-replica operation as per architecture and capacity plan.****